NOTE The roles defined by the OAuth2 framework are also known by different names when used in the context of OpenID Connect. The OAuth2 Authorization Server is also called the *OIDC Provider*. The OAuth2 Client, which relies on the Authorization Server for authentication and token issuing, is also called the *Relying Party* (RP). The OAuth2 User is also called the *End-User*. We'll stick to the OAuth2 naming for consistency, but it's helpful to know the alternative terminology used in OIDC.

In Polar Bookshop, Edge Service will initiate the user login flow, but then it will delegate the actual authentication step to Keycloak via the OIDC protocol (supported out of the box by Spring Security). Keycloak provides several authentication strategies, including traditional login forms, social logins via providers like GitHub or Twitter, and SAML. It also supports two-factor authentication (2FA). In the following sections, we'll use the login form strategy as an example. Since users will interact directly with Keycloak to log in, their credentials will never be exposed to any component of the system except Keycloak, which is one of the benefits of adopting such a solution.

When an unauthenticated user calls a secure endpoint exposed by Edge Service, the following happens:

1. Edge Service (the Client) redirects the browser to Keycloak (the Authorization Server) for authentication.
2. Keycloak authenticates the user (for example, by asking for a username and password via a login form) and then redirects the browser back to Edge Service, together with an *Authorization Code*.
3. Edge Service calls Keycloak to exchange the Authorization Code with an ID Token, containing information about the authenticated user.